

GDPR from the Information Security Perspective

Dr. Kaleem Usmani

kaleem.usmani@gmail.com

kusmani@cert.ncb.mu (Alternate)

Personal Data Protection

- Personal data protection plays an important role in the digital era. The right to privacy is expressly provided in Sections 3 and 9 of the Constitution of Mauritius and Article 22 of the Mauritian Civil Code.
- Mauritius enacted the Data Protection Act in 2004. In light of the digital evolution in Mauritius, the Data Protection Act has been replaced by the new Data Protection Act 2017 which came into force on 15 January 2018.
- The Act aims at strengthening the control and personal autonomy of data subjects over their personal data and for matters related thereto. It seeks to bring Mauritius data protection framework into line with the General Data Protection Regulation (Regulation (EU) 2016/679).

Why GDPR ?

- The GDPR is a regulation that requires businesses to protect the personal data and privacy of EU citizens for transactions that occur within EU member states.
- It carries provisions that require businesses to protect the personal data and privacy of EU citizens for transactions that occur within EU member states.
- The GDPR also regulates the exportation of personal data outside the EU.

GDPR Impact on Organisations

- It will have an impact on any organisation that processes personal data.
- Breaches will apply to firms that do not have adequate customer consent for processing their personal data or violate the principle of the privacy-by-design concepts and model.
- It is important to note that both data controllers and processors are subject to the rules, especially if they fail to either carry out a privacy impact assessment or notify the concerned authority about a breach.

Characteristics of GDPR

1.Scope:

GDPR defines how EU citizens' data must be handled by countries inside and outside the EU.

2.Consent:

GDPR has changed and reinforced the conditions of consent in that it expects clear, plain language consent from data subjects in an easy, accessible and intelligible form.

3.Fines and Penalties:

GDPR sanctions substantial fines of up to €20m or four percent of annual revenue whichever is greater.

Characteristics of GDPR (Contd.)

4.Privacy by Design

Processes will need to be amended to consider privacy by design whereby the controller must apply adequate technical and organisational procedures to fulfill the requirements of GDPR and protect the rights of individuals (data subjects)

5.Data Portability

Personally identifiable data must be portable by open use of common file formats that are machine-readable when the data subject receives them.

6.Right to Access

GDPR provides the right to data subjects to request the data controller to confirm whether their personally identifiable data is being processed, where, and for what purpose. In addition to this, the data controller must provide a free electronic copy of any personally identifiable data.

Characteristics of GDPR (Contd.)

7.Right to be Forgotten

The data subject is entitled to request that the data controller permanently or on-demand delete his/her personally identifiable data, cease further distribution of the data, and demand third parties halt processing of the data.

8.Breach Notification

As a data breach is likely to result in a risk to the rights and freedoms of individuals, GDPR requires a mandatory breach notification to be submitted to the relevant authority within 72 hours of the organisation first becoming aware of the breach.

9.Data Protection Officer (DPO)

It will be mandatory for data controllers and processors to appoint a DPO

Sum-up

- IT Governance will be impacted by the requirements of the GDPR and will bring benefits as well.
- The regulations will encourage organisations to have a more secure data management approach in place.
- GDPR introduces several privacy arrangements and control mechanisms that are intended to safeguard personal identifiable data.
- Many of those controls are also recommended by the ISO 27000 series of information security standards including ISO 27001:2013, ISO 27002:2013 as well as the COBIT 5 standards.

Thank You